1.Write a brief explanation (in your own words) of what VAPT (Vulnerability Assessment and Penetration Testing) is, and list two differences between Vulnerability Assessment and Penetration Testing.

Ans-

Step 1: Understand VAPT

VAPT stands for Vulnerability Assessment and Penetration Testing.

VAPT is a security testing process used to identify weaknesses in a computer system, website, mobile application, or network.

Its main purpose is to find security vulnerabilities before hackers can exploit them.

Step 2: Write two differences

Vulnerability Assessment	Penetration Testing
Identifies security weaknesses.	Tests whether weaknesses can be exploited.
Focuses on finding vulnerabilities.	Focuses on exploiting vulnerabilities in a controlled way.

2.Imagine you are performing a VAPT for a food delivery app like Zomato. Identify and describe three common vulnerabilities you would check for in such an app.

Ans-

Step 1: SQL Injection

High Risk – Potential

Meaning: SQL Injection occurs when an application does not properly validate user input, allowing malicious SQL commands to affect database queries.

Example: An attacker may try to manipulate the login form to access unauthorized database information.

Prevention:

- Use parameterized SQL queries.
- Validate user input.
- Use secure database permissions.

Step 2: Broken Authentication

High Risk – Potential

Meaning: Broken authentication occurs when login and authentication mechanisms are not properly secured.

Example: An attacker may gain unauthorized access to another user's account due to weak authentication or session management.

Prevention:

- Use strong password policies.
- Implement multi-factor authentication (MFA).
- Use secure session management.

Step 3: Insecure Direct Object Reference (IDOR)

High Risk – Potential

Meaning: IDOR occurs when an application does not properly check whether a user has permission to access a particular resource.

Example: A customer changes an order ID in an API request and accesses another customer's order details.

Prevention:

- Implement proper authorization checks.
- Verify user ownership of every requested resource**.**
- Never rely only on hidden or unpredictable IDs.

3.Create a sample VAPT report template in a Word or Google Docs file for a fictional e-wallet app (like Paytm). Your template should include sections for Executive Summary, Methodology, Vulnerabilities Found, Risk Ratings, and Recommendations.

Ans-

VULNERABILITY ASSESSMENT AND PENETRATION TESTING (VAPT) REPORT

Fictional E-Wallet Application: SafeWallet

Document status: Sample Template | Version: 1.0 | Date: [DD-MMM-YYYY]

Prepared by: [Tester / Team Name] | Reviewed by: [Reviewer Name]

Confidentiality: This report is intended only for the authorized application owner and stakeholders.

1. Executive Summary

[Briefly describe the purpose and scope of the assessment, the testing period, and the overall security posture. Summarize the number of findings by severity and the most important business risks.]

Severity	Number of Findings
Critical	[ ]

High	[ ]
Medium	[ ]
Low	[ ]
Informational	[ ]

2. Assessment Details

Application name: SafeWallet (fictional e-wallet)

Application version / environment: [Version; staging/production]

Assessment dates: [Start date] to [End date]

Authorized scope: [Domains, APIs, mobile apps, IP ranges, test accounts]

Out of scope: [Systems or activities excluded]

Authorization reference: [Written approval / ticket number]

3. Methodology

Describe the approved approach and standards used. Example activities:

Planning and scoping: confirm written authorization, targets, test accounts, limits, and emergency contacts.

Information gathering: identify application components, endpoints, technologies, and exposed services.

Vulnerability assessment: review configurations and test for common weaknesses, including access control, authentication, input validation, and data protection.

Controlled penetration testing: safely validate selected findings using non-destructive test cases and agreed limits.

Analysis and reporting: rate risk, document evidence, explain impact, and recommend remediation.

Retesting: verify fixes after the application owner has deployed them.

Reference guidance: OWASP Web Security Testing Guide and OWASP Top 10 (record the exact versions used).

4. Vulnerabilities Found

Duplicate this finding record for each issue identified.

Finding [ID]: [Vulnerability Title]

Severity / CVSS: [Critical / High / Medium / Low / Informational; score and vector if calculated]

Affected asset: [URL, API endpoint, mobile component, or database]

Description: [What the weakness is and where it occurs]

Evidence: [Sanitized request/response, screenshot reference, log excerpt, or reproduction summary. Remove secrets and personal data.]

Impact: [What an attacker could realistically do and the business/customer impact]

Likelihood: [Why exploitation is easy, difficult, or conditional]

Recommendation: [Specific technical fix and any compensating controls]

References: [Relevant standard, secure coding guidance, or vendor documentation]

Owner / Due date: [Responsible team and target remediation date]

5. Risk Ratings

Use the organization's approved risk matrix. The following is an illustrative guide; adjust it to the business context.

Rating	Typical meaning	Suggested priority
Critical	Severe impact; likely compromise of sensitive data or core services	Immediate action
High	Significant impact or exposure of important customer/business data	Urgent; prioritize
Medium	Limited or conditional impact; meaningful security weakness	Plan and remediate
Low	Limited impact or difficult to exploit	Address in normal cycle
Informational	Hardening advice or observation without direct demonstrated impact	Consider improvement

6. Recommendations and Remediation Plan

[Prioritized action 1] — Owner: [Team] — Target date: [Date]

[Prioritized action 2] — Owner: [Team] — Target date: [Date]

Apply secure development practices, access controls, encryption, logging, and security monitoring as appropriate.

Retest all remediated findings and record the result: Fixed / Partially Fixed / Not Fixed / Risk Accepted.

7. Conclusion

[Summarize the overall result, key residual risks, and whether the application is ready for the intended release, subject to the stated limitations.]

8. Limitations and Assumptions

[Testing limitations, unavailable components, rate limits, test data constraints, or time restrictions.]

Only systems explicitly authorized in writing were tested. No destructive actions or real customer transactions were performed.

9. Approval

Role	Name	Signature / Date
Tester	[Name]	[ ]
Application Owner	[Name]	[ ]

Appendix A — Sample Finding (Plain-Text Password Storage)

Finding ID: AUTH-01

Title: User passwords stored in plain text

Severity: Critical (illustrative; confirm using the organization's risk matrix and actual exposure)

Affected asset: Movie ticket booking application — user authentication database

Description: User passwords are stored in readable plain text rather than being protected with a password-hashing function. Anyone who obtains read access to the database, backups, or logs may be able to view users' passwords.

Impact: Attackers or unauthorized insiders could take over user accounts. If customers reuse passwords on other services, those accounts may also be at risk. A database exposure could therefore cause account compromise and loss of customer trust.

Recommendation: Do not store passwords in plain text. Store passwords using a modern, salted, adaptive password-hashing algorithm such as Argon2id (or an appropriately configured bcrypt/scrypt implementation). Use a unique salt per password, set secure work factors, restrict database access, protect backups, and ensure passwords are never written to application logs. After fixing the issue, require affected users to reset their passwords and review access logs for possible exposure.

**4.Given the following scenario: During a VAPT of a movie ticket booking app, you discover that user passwords are stored in plain text in the database. Write a short VAPT report entry describing this vulnerability, its risk level, and a recommendation to fix it.

Hint: Use clear, professional language and cover what the risk is and how to mitigate it.**

Ans-

Step 1: Identify the vulnerability During VAPT of a movie ticket booking application, you discover that user passwords are stored in plain text in the database.

Step 2: Identify the risk level

Critical Risk – Illustrative

Reason: Anyone who gains unauthorized access to the database may read users' passwords directly.

Step 3: Write the VAPT report

Vulnerability Title: Plain Text Password Storage

Affected Application: Movie Ticket Booking Application

Description:

During security testing, it was identified that user passwords are stored in plain text instead of being securely hashed in the database.

Risk Level: Critical

Impact:

- Attackers may access users' passwords.
- User accounts may be compromised.
- Attackers may misuse customer accounts.
- Users who reuse passwords on other websites may also be affected.

Recommendation:

- Never store passwords in plain text.
- Use secure password hashing algorithms such as Argon2id or bcrypt.
- Use a unique salt for every password.
- Implement proper database access controls.
- Force affected users to reset their passwords if exposure is suspected.

Conclusion:

The application should implement secure password hashing to protect user credentials and prevent unauthorized account access.